

DVWA (Damn Vulnerable Web Application):

Paso 1: Preparación y acceso al entorno vulnerable

- Abre el navegador y accede a la URL local donde está desplegada la aplicación DVWA, usualmente <http://localhost/dvwa>.
- Inicia sesión con las credenciales proporcionadas para entorno de pruebas (por defecto: usuario [admin](#), contraseña [password](#)).
- En la sección "DVWA Security" dentro de la aplicación, selecciona el nivel de seguridad [Low](#) para permitir la ejecución sin filtros restrictivos ni mecanismos de mitigación que bloqueen la explotación.

Este paso asegura que el entorno está listo para pruebas de penetración con la menor interferencia posible, emulando condiciones típicas de vulnerabilidad.

Paso 2: Navegación al módulo vulnerable

- Desde el menú lateral de la aplicación, selecciona el módulo titulado "Command Injection".
- Observa que este módulo presenta un formulario que solicita una dirección IP para ejecutar un comando [ping](#) y mostrar el resultado.
- Entiende que el campo para la dirección IP es vulnerable si la aplicación no filtra o valida correctamente la entrada.

En esta etapa se define el vector de ataque: la entrada de texto que será utilizada para inyectar comandos del sistema operativo.

Paso 3: Ejecución de prueba básica de inyección de comandos

En el campo para la dirección IP, introduce una IP válida seguida de un separador de comandos del shell para Linux, por ejemplo:

```
127.0.0.1; whoami
```

- Envía el formulario para que el servidor procese la petición.
- Observa la respuesta: si la salida del comando [whoami](#) se muestra junto con el resultado del ping, confirma la ejecución remota de comandos arbitrarios.

Técnicamente, el carácter `;` en shells Unix/Linux permite concatenar comandos; al no sanitizar esta entrada, el sistema interpreta y ejecuta el segundo comando `whoami` además del `ping`.

Paso 4: Ejecución de pruebas avanzadas y validación

Repite el proceso con otros comandos controlados para obtener más información del sistema o validar la vulnerabilidad:

```
127.0.0.1; uname -a
```

```
127.0.0.1 && id
```

-
- Analiza la salida para corroborar que los comandos se ejecutan con éxito y bajo qué usuario o entorno del sistema operativo.
- Prueba diferentes separadores de comandos comunes (`;`, `&&`, `|`) para evaluar cómo se comporta la aplicación ante distintas técnicas de inyección.

Este paso confirma el alcance y la versatilidad de la vulnerabilidad, permitiendo entender mejor el riesgo.

Paso 5: Análisis técnico y documentación del hallazgo

- Documenta de manera profesional la vulnerabilidad siguiendo un formato estándar:
 - **Título del hallazgo:** Ejemplo "Ejecución remota de comandos por inyección en módulo Command Injection de DVWA".
 - **Descripción técnica:** Explica que el módulo ejecuta directamente la entrada del usuario como parte de un comando shell sin validación, permitiendo ejecución arbitraria.
 - **Evidencia técnica:** Registra los comandos usados, capturas de pantalla o logs que muestren las respuestas con los resultados de los comandos ejecutados.
 - **Evaluación del riesgo:** Detalla que esta vulnerabilidad permite compromiso completo del servidor, acceso no autorizado a datos y posible escalamiento de privilegios.
 - **Recomendaciones de mitigación:** Propón validación estricta de entradas, prohibición de concatenación directa en comandos, uso de APIs seguras

- para ejecución, y principios de menor privilegio para procesos.
- **Referencias:** Incluye estándares OWASP, CWE-78 (OS Command Injection) y CVSS para la valoración de riesgos.

Este paso es fundamental para comunicar claramente los riesgos y las soluciones a los responsables del sistema.

Consideraciones técnicas adicionales para mitigación

- Implementar un whitelist para validación de la entrada, permitiendo solo direcciones IP en formato numérico estándar, rechazando cualquier caracter especial o separadores de comandos.
- Utilizar funciones del lenguaje servidor que eviten la ejecución directa de shell o que permitan ejecutar comandos de forma segura, como escapes específicos o librerías dedicadas.
- Configurar el servidor web y sistema operativo para que el proceso que ejecute la aplicación tenga mínimos privilegios y esté aislado, reduciendo el impacto ante una explotación.
- Registrar y monitorear intentos de inyección mediante logs para detección temprana y respuesta a incidentes.